Seguridad en Sistemas de Bases de Datos

Índice

Seguridad en Sistemas de Bases de Datos 1
Índice 1
Introducción 1
Control Discrecional 2
GRANT y REVOKE 3
GRANT 3
REVOKE 4
Vistas y Seguridad 5
Seguridad mediante el uso de Stored Procedures 6
Roles y Grupos de Autorización 6
Roles 6
Grupos o Perfiles 6

Introducción

A menudo los temas de seguridad de datos son agrupados junto a los de integridad de datos (al menos en contextos informales) pero los dos conceptos son muy diferentes. La seguridad se refiere a la protección de datos contra la divulgación, alteración o destrucción no autorizadas; mientras que integridad se refiere a la precisión o validez de los datos. Simplificando:

- Seguridad significa proteger los datos contra usuarios no autorizados. O asegurar que los usuarios están autorizados para hacer las cosas que intentan hacer.
- Integridad significa proteger los datos de usuarios autorizados. O asegurar que los usuarios hacen lo correcto con los datos.

Hay ciertas similitudes ya que en ambos casos el sistema debe ser consciente de algunas limitaciones (constraints) que los usuarios no deben violar. Esos constraints deberán ser especificados en un lenguaje adecuado, y deben resguardarse en el catálogo del sistema y, también en ambos casos, el DBMS debe supervisar las operaciones de los usuarios con el fin de garantizar que los constraints son observados.

Actualmente los DBMSs soportan típicamente uno o ambos de los dos grandes enfoques de la seguridad de datos. Estos enfoques son conocidos como *control discrecional*[1] y *control mandatario*. En cuanto al tema de granularidad de la protección se da que, en ambos casos, la unidad de datos u "objeto de datos" a ser protegida puede ir desde la base completa hasta un componente específico dentro de una tupla específica.

[1] Adj. Que se hace libre y prudencialmente

Independientemente del tipo de control que se ejerza, las decisiones de qué usuarios están autorizados a qué información son de tipo político y no técnico; lo único que puede hacer el DBMS es forzar a que esas decisiones se cumplan. En este sentido se desprende lo siguiente:

- El resultado de las decisiones políticas debe ser conocido y recordado por el sistema. Esto se logra por medio de sentencias de definición en algún lenguaje apropiado que crea un equivalente de la decisión en el catálogo.
- Dado un requerimiento de acceso debe haber un medio para chequear la información de seguridad almacenada en el catálogo. El requerimiento de acceso estará compuesto por la *operación* requerida, el *objeto* involucrado y el *usuario* que origina el pedido. Este chequeo lo realizará el subsistema de seguridad del DBMS también conocido como subsistema de autorizaciones.

El enfoque básico de la seguridad y las autorizaciones que tomaron los proveedores de DBMSs para el acceso seguro a las bases de datos es que todos los recursos sean controlados por el DBMS. No existen autorizaciones de default para los usuarios que se conecten al motor. Por lo tanto para que un usuario pueda ejecutar alguna operación debe darse alguna de las siguientes condiciones:

- Al usuario se le otorgó la posibilidad de ejecutar la operación
- La operación fue otorgada genéricamente a todos los usuarios

El desafío de administrar eficazmente la seguridad de bases de datos se debe a que la creación y gestión de bases de datos requiere expertise técnico y privilegios elevados. Muchos aspectos de seguridad de bases de datos requieren el uso de diferentes utilitarios, procedimientos de sistema, y comandos. Cuando los usuarios necesitan tener acceso a múltiples bases de datos, en múltiples servidores distribuidos en múltiples ubicaciones físicas; la administración de la seguridad de las bases de datos se torna bastante complicada.

A pesar de que el DBA es normalmente responsable de la administración de base de datos de seguridad, algunas organizaciones han trasladado esta tarea a un área de administración de la seguridad separada que funcione controlando todos los recursos de IT de la compañía. En aquellos en que sigue siendo manejado por el DBA o grupo de DBAs es porque la seguridad de las bases de datos es distinta a los típicos escenarios de autorizaciones del resto IT.

Suele suceder que la mayoría de departamentos de seguridad de II carecen de personal suficiente con perfil técnico en DBMSs necesarios para administrar la seguridad de la base de datos. Esto último sumado a que una mala gestión de seguridad puede provocar interrupciones o problemas de performance hace que el DBA esté obligado a intervenir en la gestión de la seguridad de la base de datos.

Control Discrecional

El SQL estándar actual soporta solo el control de acceso discrecional. Tres elementos del SQL, más o menos independientes, están involucrados en este esquema. El mecanismo de las Vistas que puede ser usado para ocultar datos sensitivos a usuarios

no autorizados, los Stored Procedures que permiten operar sobre las tablas base sin autorizarlas explícitamente y el Subsistema de Autorizaciones en sí mismo que permite a los usuarios armar un esquema de seguridad selectivo y dinámico.

GRANT y REVOKE

El control de la seguridad y las autorizaciones del DBMS se llevan a cabo con el Data Control Language, o DCL. DCL es uno de los tres subtipos de SQL (los otros dos son DML y DDL). Las sentencias de DCL se utilizan para controlar qué usuarios tienen acceso a qué objetos y comandos. Estas sentencias son el modo en que el DBMS toma conocimiento de la regla a hacer cumplir. Las sentencias DCL tienen dos tipos:

- GRANT que asigna permisos a un usuario
- REVOKE que remueve los permisos de un usuario

La tarea de especificar los usuarios autorizados a ejecutar de un requerimiento sobre los datos se realiza mediante la sentencia GRANT.

Tenga en cuenta que el creador de cualquier objeto obtiene automáticamente todos los privilegios, que tengan sentido, sobre ese objeto. Por Ej. El creador de la tabla T tendrá inmediatamente la posibilidad de hacer SELECT, INSERT, UPDATE, DELETE, etc. sobre T. Es mas, estos privilegios le son otorgados con la posibilidad de que él los otorgue a otros usuarios (se trata de la opción "WITH GRANT OPTION" que veremos esto mas adelante).

GRANT

Para usar la sentencia GRANT, el usuario debe ser:

- El dueño (owner) del objeto a ser autorizado
- O tener la autoridad para hacerlo por pertenecer a un grupo de usuarios especiales (como veremos mas adelante)
- O tener la posibilidad de hacerlo debido a que se le otorgaron permisos con la opción "WITH GRANT OPTION"

La sintaxis básica de la sentencia es la siguiente:

```
GRANT <Lista de privilegios separados por comas>
        ON <Objeto>
        TO <Lista de id de usuarios separados por comas>
        [WITH GRANT OPTION]
```

- Los <*privilegios*> válidos son USAGE, SELECT, INSERT, UPDATE, DELETE y REFERENCES. El privilegio USAGE se necesita para hacer uso de un dominio específico (o tipo de dato definido por el usuario del estilo SQL); el privilegio REFERENCES se necesita para referirse a un determinado constraint

de integridad de la tabla nombrada como objeto; los demás son auto explicativos.

- The <*objetos*> válidos son DOMAIN <*nombre de dominio*> y TABLE <*nombre de tabla*>. TABLE es opcional y puede hacer referencia a una vista.
- La < Lista de id de usuarios separados por comas> puede reemplazarse por la palabra reservada PUBLIC, para indicar a todos los usuarios definidos en el sistema. Los grants a PUBLIC no pueden usar la opción WITH GRANT OPTION. Reserve el uso de PUBLIC para aquellas pocas bases u objetos que deban estar disponibles para cualquiera.
- WITH GRANT OPTION permite a los usuarios pasara la autoridad de otorgar el privilegio a otros. Generalmente, el uso de esta cláusula depende de las prácticas de la instalación en lo que a administración de privilegios se refiere. Estas pueden ser centralizadas o descentralizadas.
    - Descentralizadas es generalmente mas fácil de establecer, pero mas dificultosa en el control. A medida que más y más usuarios obtienen la autoridad para conceder privilegios, el alcance de la autoridad se amplía y se convierte en difícil de manejar.
    - Centralizada es generalmente mas fácil de administrar, pero carga al administrador por ser el único en manejar los privilegios en el entorno.

REVOKE

Ahora, si el usuario A otorga algún privilegio a algún usuario B, el usuario A puede, posteriormente, quitar tal privilegio del usuario B. Para quitar estos privilegios se utiliza la sentencia REVOKE que tiene la siguiente sintaxis:

```
REVOKE [GRANT OPTION FOR] <Lista de privilegios separados por comas>
        ON <Objeto>
        FROM <Lista de id de usuarios separados por comas>
        <Opción>
```

- GRANT OPTION FOR significa que se quitará la posibilidad de propagar la autorización a otros usuarios
- < Lista de privilegios separados por comas >, < Objeto > y < Lista de id de usuarios separados por comas > están explicadas en la sentencia GRANT
- <opción> es RESTRICT o CASCADE, y se discute a continuación

RESTRICT vs. CASCADE: Supongamos que P es un privilegio de algún objeto, y supongamos que un usuario A otorga P al usuario B, que a su vez le otorga P al usuario C. ¿Qué sucederá si quita P al usuario B? Entonces, el privilegio P en manos de C quedaría "abandonado" (el privilegio deriva da B que ya no lo tiene). La idea de las opciones RESTRICT o CASCADE es manejar el hecho de tener privilegios abandonados. Para ser específico, RESTRICT provoca que el REVOKE falle si el usuario B tiene permisos otorgados; CASCADE hace que todos los privilegios de B y los que haya otorgado caigan.

Por último el hecho de dropear un dominio, una tabla o vista, automáticamente elimina todas las autorizaciones otorgadas sobre dichos objetos.

Vistas y Seguridad

El mecanismo de Vistas permite que la base sea conceptualmente dividida en partes de modo que la información sensitiva pueda ocultarse a usuarios no autorizados. Sin embargo, no permite especificar las operaciones que se les permite ejecutar a los usuarios autorizados sobre cada una de las partes. Esta tarea le queda a la sentencia GRANT.

Para ilustrar esta modalidad presentamos algunos ejemplos:

```
CREATE VIEW SOLOBSAS AS
        SELECT RAZÓN _ SOCIAL, LOCALIDAD, TELEFONO
        FROM COMERCIOS
        WHERE PROVINCIA=’BUENOS AIRES’
```

La vista define los datos sobre los que operará la autorización. Una sentencia GRANT podría ser:

```
GRANT SELECT
        ON SOLOBSAS
        TO USUARIO_A, USUARIO_B
```

Este permiso otorga la posibilidad de que los usuarios USUARIO_A y USUARIO_B puedan ver datos de la tabla COMERCIOS pero solo de aquellos comercios de Buenos Aires (es lo que filtra el WHERE en la creación de la vista.

La vista no se modifica (en cuanto a las filas que muestra) si no lo hace la tabla base. Hay vistas que modifican su resultado dependiendo del contexto en que operan. Por Ej.

```
CREATE VIEW SEGÚN_USER AS
        SELECT APELLIDO, NOMBRE, EDAD
        FROM CLIENTES
        WHERE PRESENTADO_POR=CURRENT USER
```

La vista anterior devolverá diferentes resultados dependiendo de qué usuario ejecute la consulta. Otorgar permisos a esta vista significaría que cada usuario puede ver la información de aquellos clientes que fueron presentados por él.

Seguridad mediante el uso de Stored Procedures

Los Stored procedures (SP) pueden usarse para proveer un nivel adicional de seguridad. El privilegio de ejecutar un SP debe ser explícitamente otorgado o quitado independientemente de la seguridad implementada en las tablas base.

Los SP pueden codificarse para que accedan a determinadas filas y columnas. Puede otorgarse a un usuario la posibilidad de ejecutar un SP y, aunque no tenga la posibilidad de acceder a las tablas base éste tendrá posibilidad de operar sobre ellas a través de la lógica del SP generando así un nivel extra de seguridad.

Roles y Grupos de Autorización

Adicionalmente a la posibilidad de otorgar privilegios a usuarios individuales los DBMSs pueden tener la capacidad de otorgar:

- Privilegios específicos a un Rol que a su vez es otorgado a otros usuarios
- Grupos de privilegios predefinidos a los usuarios

Por supuesto la terminología no es compartida por los distintos DBMSs, algunos llaman grupos a los roles y viceversa.

Roles

Una vez definido un Rol, este puede ser usado para otorgar uno o más privilegios preasignados a un usuario. Un rol es esencialmente una colección de privilegios.

En el siguiente ejemplo se crea el rol MANAGER que finalmente será otorgado al usuario USER1 por lo que finalmente USER1 contará con los permisos otorgados a MANAGER

```
CREATE role MANAGER;
COMMIT;
GRANT select, insert, update, delete on employee to MANAGER;
GRANT select, insert, update, delete on job_title to MANAGER;
GRANT execute on payroll to MANAGER;
COMMIT;
GRANT MANAGER to user1;
COMMIT;
```

Grupos o Perfiles

La autoridad a nivel de grupo/perfil es similar a los roles, sin embargo, cada DBMS provee sus grupos/perfiles predefinidos y no pueden ser cambiados. A pesar de que las implementaciones tienen distinta formas, nombres y privilegios hay algunas similitudes entre los DBMS. Los siguientes grupos/perfiles son comunes a la mayoría:

- *System administrator*. A veces abreviado SA o SYSADM, el grupo/perfil system administrator es el más poderoso dentro del DBMS. Un usuario con SA típicamente puede ejecutar todos los comandos y acceder a todas las bases y

objetos. El system administrator es usualmente el responsable de la instalación del DBMS.

- *Database administrator*. A veces abreviado DBADM o DBA, el grupo/perfil database administrator tiene todos los privilegios sobre una base específica, además de la posibilidad de acceder, pero no modificar, los datos en las tablas dentro de la base. Los usuarios asignados al grupo/perfil de DBA pueden dropear y alterar cualquier objeto dentro de la base (tablespaces, tablas, e índices).
- *Database maintenance*. A veces abreviado DBMAINT, el grupo/perfil database maintenance incluye los privilegios para el mantenimiento de los objetos de la base (tales como la posibilidad de ejecutar utilitarios y ejecutar comandos). Al igual que el grupo/perfil DBA, el privilegio DBMAINT se otorga por cada base.
- *Security administrator*. El rol de administrador de seguridad tiene la posibilidad de otorgar privilegios dentro del DBMS usando las sentencias de grant y revoke. El administrador de seguridad puede ejecutar cualquier actividad relacionada con la seguridad incluyendo l administración del login y la password, auditoria, el diseño de la configuración de seguridad, como así también los GRANTs y REVOKEs. SSO es otro nombre común para el administrador de la seguridad.
- *Operations control*. Algunas veces conocido como OPER o SYSOPR, el controlador de operaciones tiene la autoridad de ejecutar tareas operativas tales como backup y recovery, o cancelar tareas que no estén trabajando correctamente.